EPI Quantum Crypto team
Cryptographie appliquée et évaluation des sources d'entropie

NOTE TECHNIQUE · VERSION 5.1

Évaluation d'entropie NIST SP 800-90B en bibliothèque C

libsp80090b : mesurer la min-entropie d'une source de bruit sur la machine cible, décider de sa conformité et dimensionner un générateur hybride

RÉFÉRENCE	NT-01
OBJET	libsp80090b : méthode d'évaluation d'une source d'entropie selon SP 800-90B
VERSION	5.1 — septembre 2026
AUTEURS	EPI Quantum Crypto team
DIFFUSION	Note technique — diffusion publique
RÉFÉRENTIELS	NIST SP 800-90A, SP 800-90B, SP 800-90C ; FIPS 140-3 (IG D.K)
DOCUMENTS LIÉS	NT-02 Guide d'utilisation (API et labs) ; NT-03 Guide de bonnes pratiques ; version anglaise : NT-01 (en)
REMPLACE	NT-01 v5.0

RÉSUMÉ

Pour un générateur physique d'aléa (TRNG), l'évaluation de l'entropie demande un effort rigoureux : modéliser la source de bruit, capturer des millions d'échantillons bruts dans les conditions réelles d'emploi, puis exécuter des tests statistiques longs. Cet effort est indispensable, car un générateur déterministe (DRBG) ne crée pas d'entropie : il étire celle de sa graine. La sécurité de toute la chaîne cryptographique repose donc sur une seule grandeur, la **min-entropie par échantillon** H de la source de bruit, que la recommandation **NIST SP 800-90B** [1] estime par quatre tests.

libsp80090b est un portage en C99 de l'outil de référence du NIST [2] sous forme de bibliothèque : ses quatre fonctions évaluent un tampon en mémoire, directement sur la machine cible. Elle donne les mêmes valeurs que l'outil du NIST, et une campagne de 52 cas sur 22 jeux de données confirme que chaque test réagit comme la théorie le prévoit, avec ses limites : aucun test statistique ne distingue une sortie de DRBG d'un vrai bruit. La note explique la méthode, de la mesure au dimensionnement de la graine et des tests de santé d'un générateur hybride.

Mots-clés : SP 800-90B ; min-entropie ; IID ; non IID ; redémarrage ; conditionnement ; tests de santé ; générateur hybride ; DRBG ; SP 800-90C

Sommaire

1 Introduction et contexte 3
1.1 Objectifs de l'évaluation SP 800-90B 3
1.2 Vocabulaire 3
2 Pourquoi une bibliothèque 3
2.1 Le besoin : mesurer sur la machine cible 3
2.2 Limites de l'outil de référence du NIST 3
2.3 Apport de libsp80090b 4
3 Le cadre de qualification SP 800-90B 4
3.1 Modéliser, puis mesurer 5
3.2 Évaluation hors ligne et surveillance en continu 6
4 Les quatre tests de SP 800-90B 6
4.1 Test 1 : l'hypothèse IID (section 5) 6
4.2 Test 2 : les estimateurs non IID (section 6.3) 6
4.3 Test 3 : le redémarrage (section 3.1.4) 7
4.4 Test 4 : le conditionnement (section 3.1.5) 7
5 Décider si une source est conforme 7
6 Intégration dans un générateur hybride 8
6.1 Entropie à fournir au DRBG 8
6.2 Nombre d'échantillons bruts 8
6.3 Seuils des tests de santé 8
7 Enseignements des labs 9
8 Conclusion 9
9 Références 9

1 Introduction et contexte

Une source d'entropie défaillante ne signale jamais sa propre panne. Une source biaisée, corrélée ou figée alimente le DRBG comme une bonne source, et le DRBG produit une sortie qui réussit tous les tests statistiques. La vulnérabilité n'apparaît que lorsqu'un attaquant parvient à reconstituer la graine. La seule protection consiste à **mesurer la min-entropie du bruit brut** avant tout traitement, puis à surveiller la source en continu.

1.1 Objectifs de l'évaluation SP 800-90B

1. **Garantir la sécurité cryptographique.** S'assurer que l'entropie requise, par exemple 256 bits pour la graine, est réellement présente.
2. **Détecter les défaillances matérielles.** Vieillissement, variations de température ou de tension, perturbations de l'environnement.
3. **Dimensionner le générateur.** Déduire de H le nombre d'échantillons $N = \lceil E / H \rceil$ à collecter pour ensemencer le DRBG, et les seuils des tests de santé RCT et APT.

1.2 Vocabulaire

Tableau 1. Notions employées dans ce document.

Terme	Définition
Source de bruit	Composant physique ou logique non déterministe : gigue d'horloge, oscillateur en anneau, bruit thermique
Échantillon (symbole)	Valeur numérisée produite par la source, de 1 à 8 bits, stockée à raison d'un échantillon par octet
Bruit brut	Échantillons avant tout traitement ou conditionnement. Seul objet légitime d'une évaluation
Min-entropie H	$H = -\log_2(p_{max})$, où p_{max} est la probabilité de la valeur la plus probable : la difficulté du meilleur pari d'un adversaire
IID	*Independent and Identically Distributed* : échantillons indépendants et de même loi
$\mathbf{H_{original}}$, $\mathbf{H_{bitstring}}$	Min-entropie des échantillons tels quels, et de la suite de leurs bits
$\mathbf{H_I}$	Entropie initiale : $\min(H_{original}, n \times H_{bitstring})$ pour des échantillons de n bits
Conditionnement	Fonction déterministe (SHA-256, HMAC, CBC-MAC) qui concentre l'entropie sans en créer
Force de sécurité s	Effort, en bits, pour prédire la sortie du DRBG : s = 256 dans nos générateurs

2 Pourquoi une bibliothèque

2.1 Le besoin : mesurer sur la machine cible

L'entropie n'est pas une constante d'un composant : elle varie avec la fréquence du processeur, la charge, la température et la virtualisation. Sur une machine virtuelle, la même source de gigue a donné 2,67 bits par échantillon lors d'une campagne, puis 1,16 bit lors d'une autre [10]. Une évaluation faite une fois, en laboratoire, sur un fichier capturé ne garantit donc pas la valeur sur la machine de production.

2.2 Limites de l'outil de référence du NIST

L'outil du NIST, SP800-90B_EntropyAssessment [2], est la référence : c'est lui qui produit les résultats d'un dossier de validation. Mais c'est un ensemble d'exécutables C++11 qui travaillent hors ligne :

- il exige l'écriture des données sur disque, puis leur relecture ;

- il ne fournit aucune API : le résultat s'extrait d'une sortie texte ou JSON ;
- il dépend de bibliothèques lourdes (libstdc++, jsoncpp, bzip2, gmp, mpfr, OpenSSL), souvent absentes des environnements embarqués.

2.3 Apport de libsp80090b

libsp80090b réalise les quatre tests de la norme par **quatre fonctions C99** qui travaillent directement sur un tampon en mémoire :

Évaluation non IID d'un tampon de 1 000 000 d'échantillons

```
#include "sp80090b.h"

sp80090b_options_t opt = sp80090b_default_options();
sp80090b_result_t res;
opt.bits_per_symbol = 8;

/* non-IID track on 1,000,000 raw samples held in memory */
if (sp80090b_non_iid_evaluate_ex(buffer, 1000000, &opt, &res) == SP80090B_OK
    && res.warnings == 0)
    printf("Assessed min-entropy H_I = %.5f bits per sample\n", res.h_assessed);
```

Tableau 2. Les quatre fonctions de l'API.

Fonction	Test	Rôle
`sp80090b_iid_evaluate_ex()`	1 (§5)	Vérifie l'hypothèse IID : khi-deux, plus longue répétition, 10 000 permutations
`sp80090b_non_iid_evaluate_ex()`	2 (§6.3)	Calcule les dix estimateurs non IID
`sp80090b_restart_evaluate()`	3 (§3.1.4)	Contrôle de cohérence et entropie au redémarrage, sur une matrice 1 000 × 1 000
`sp80090b_conditioning_evaluate()`	4 (§3.1.5)	Entropie de sortie d'une fonction de conditionnement

Le suffixe `_ex` (*extended*) désigne les fonctions de la version 2, qui prennent une structure d'options. Les quatre labs de la campagne de validation appellent ces fonctions par l'intermédiaire de petits programmes (`test_iid`, `test_non_iid`, `test_restart`, `test_conditioning`) ; leur emploi est décrit dans NT-02.

Conformité. Sur les onze jeux de référence du NIST, la voie non IID est identique à l'outil du NIST à 7,2 × 10^{-14} près, et la voie IID en reproduit toutes les statistiques déterministes au bit près (`make check`, NT-02).

La bibliothèque ne remplace pas trois choses : la **modélisation** de la source, travail du concepteur ; les **tests de santé**, qui restent dans le produit ; et le **dossier de validation ESV**, constitué avec l'outil du NIST et évalué par le NIST lui-même [5].

3 Le cadre de qualification SP 800-90B

SP 800-90B décompose une source d'entropie en trois étages : la **source de bruit**, d'où vient l'entropie ; les **tests de santé**, qui vérifient qu'elle fonctionne encore ; et un **conditionnement** facultatif. La figure 1 situe chaque test dans la chaîne complète d'un générateur, de la source au DRBG de SP 800-90A [12], dans une construction de SP 800-90C [3].

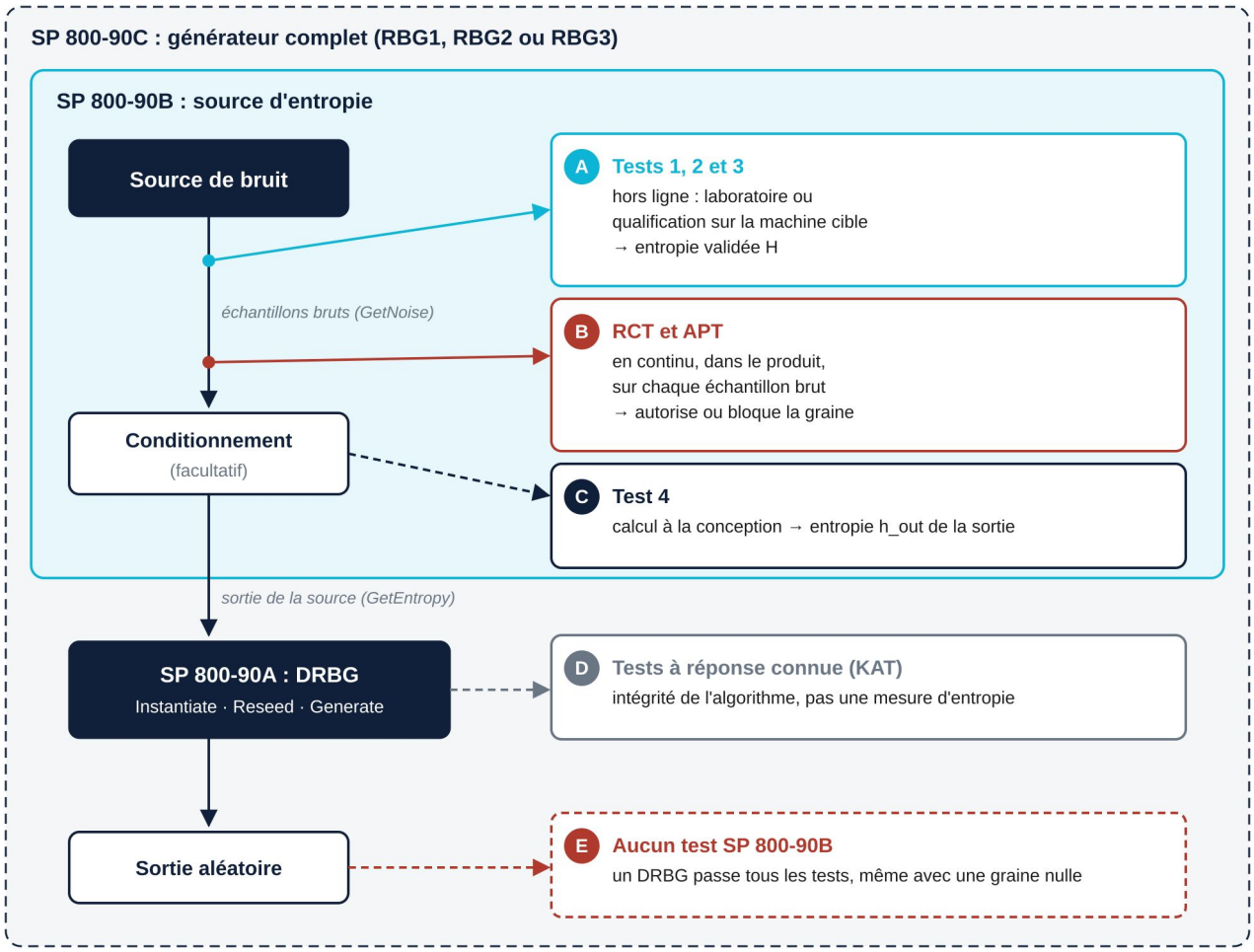


Figure 1. Place des tests dans la chaîne SP 800-90B, 90A et 90C : en cyan l'évaluation hors ligne, en rouge la surveillance en continu.

3.1 Modéliser, puis mesurer

Le NIST impose deux démarches complémentaires [11] :

1. **Le modèle.** Une justification physique du bruit, qui fixe une revendication d'entropie H_{claim} par échantillon.
2. **L'estimation statistique.** Un contrôle « boîte noire » du bruit brut, réalisé par libsp80090b. Sans connaître l'intérieur de la source, il peut se tromper : il contrôle le modèle, il ne le remplace pas.

> **Règle.** L'entropie retenue pour dimensionner le générateur est toujours la plus basse des deux : $H = \min(H_{claim}, H_{mesuré})$.

3.2 Évaluation hors ligne et surveillance en continu

Tableau 3. Évaluation hors ligne et surveillance en continu.

Critère	Évaluation hors ligne (libsp80090b)	Surveillance en continu (RCT et APT)
Objectif	Mesurer la min-entropie H de la source	Détecter une panne de la source
Données	1 000 000 d'échantillons et 1 000 redémarrages	Chaque échantillon, au moment où il est produit
Moment	Qualification, installation, mise à jour du noyau ou du matériel	En permanence, dès le démarrage
Coût	Lourd : environ 250 Mo, de quelques secondes à 2 heures de calcul	Très léger : quelques octets, quelques opérations par échantillon
En cas d'échec	Source refusée, ou revendication revue à la baisse	Graine en cours jetée, sortie arrêtée, alerte

Les deux familles se complètent : l'évaluation hors ligne donne la valeur H, la surveillance en continu vérifie que la source ne tombe pas sous cette valeur, puisque ses seuils sont calculés à partir de H.

4 Les quatre tests de SP 800-90B

4.1 Test 1 : l'hypothèse IID (section 5)

- **But.** Vérifier que les échantillons sont indépendants et de même loi. Si c'est le cas, un seul estimateur suffit : la valeur la plus fréquente (MCV).
- **Données.** Au moins 1 000 000 d'échantillons bruts consécutifs.
- **Méthode.** Deux tests du khi-deux, indépendance et adéquation (§5.2.1 à §5.2.4) ; le test de la plus longue répétition (§5.2.5) ; enfin 10 000 permutations aléatoires du fichier (§5.1), sur lesquelles on recalcule 19 statistiques : excursion, suites croissantes et décroissantes, suites autour de la médiane, collisions, périodicité, covariance et compression bzip2.
- **Décision.** Pour chaque statistique i, les compteurs $C_{i,0}$, $C_{i,1}$ et $C_{i,2}$ comptent les permutations dont la statistique est plus grande, égale ou plus petite que celle des données. Si $C_{i,0} + C_{i,1} \leq 5$ ou $C_{i,1} + C_{i,2} \leq 5$, l'hypothèse IID est **rejetée** et la source passe au test 2.
- **Durée.** Moins d'une minute pour une source IID ; de 40 minutes à 2 heures pour une source non IID, qui fait les 10 000 permutations.

> **Attention.** Une source ne suit la voie IID **que si son concepteur a justifié cette hypothèse**. Passer les tests IID ne prouve pas l'indépendance [11] : en cas de doute, appliquer le test 2.

4.2 Test 2 : les estimateurs non IID (section 6.3)

- **But.** Estimer la min-entropie sans aucune hypothèse d'indépendance : c'est le cas de presque toutes les sources physiques.
- **Méthode.** Dix estimateurs, chacun à la recherche d'une forme de régularité ; quatre sont des prédicteurs, qui tentent de deviner l'échantillon suivant [7].

Tableau 4. Les dix estimateurs non IID.

Estimateur	§	Principe	Appliqué à
Valeur la plus fréquente (MCV)	6.3.1	Fréquence du symbole le plus fréquent	Échantillons et bits
Collision	6.3.2	Temps moyen avant la répétition d'une valeur	Bits seulement
Markov	6.3.3	Chaîne de Markov d'ordre 1	Bits seulement
Compression	6.3.4	Statistique de Maurer sur des blocs de 6 bits	Bits seulement
t-uplet	6.3.5	Fréquence des t-uplets les plus répétés	Échantillons et bits
Plus longue répétition (LRS)	6.3.6	Collisions de sous-chaînes longues, par tableau des suffixes [8]	Échantillons et bits
MultiMCW	6.3.7	Prédicteur : valeur majoritaire sur quatre fenêtres glissantes	Échantillons et bits
Lag	6.3.8	Prédicteur : valeur observée d positions plus tôt ($d \le 128$)	Échantillons et bits
MultiMMC	6.3.9	Prédicteur : modèles de Markov d'ordres 1 à 16	Échantillons et bits
LZ78Y	6.3.10	Prédicteur : dictionnaire de type LZ78	Échantillons et bits

- **Résultat.** $H_{original}$ et $H_{bitstring}$ sont le minimum des estimateurs applicables ; l'entropie initiale est $H_I = \min(H_{original}, n \times H_{bitstring})$.
- **Durée.** De 5 secondes à 1 minute pour 10^6 échantillons.

4.3 Test 3 : le redémarrage (section 3.1.4)

- **But.** Vérifier que l'entropie mesurée en régime établi est bien présente dès la mise sous tension : pas d'état initial figé ou récurrent.
- **Données.** Une matrice M de r = 1 000 redémarrages réels et c = 1 000 échantillons par redémarrage. La ligne i contient le redémarrage i ; la colonne j réunit le j-ième échantillon de chaque redémarrage.
- **Contrôle de cohérence** (§3.1.4.3). L'effectif de la valeur la plus fréquente de chaque ligne et de chaque colonne ne doit pas dépasser un seuil X_{cutoff}, obtenu par simulation pour un risque global de 0,01 [6]. Une source qui redémarre toujours dans le même état donne une colonne constante et échoue.
- **Validation** (§3.1.4.2). Les estimations sur les lignes (H_r) et sur les colonnes (H_c) doivent vérifier $\min(H_r, H_c) \ge H_I / 2$.
- **Résultat.** L'entropie validée est $H = \min(H_r, H_c, H_I)$.

4.4 Test 4 : le conditionnement (section 3.1.5)

- **But.** Calculer l'entropie h_{out} qui reste après une fonction de conditionnement, par exemple SHA-256.
- **Fonction approuvée** (HMAC, CMAC, CBC-MAC, SHA-2, SHA-3, Hash_df). h_{out} se calcule par la formule Output_Entropy(n_{in}, n_{out}, nw, h_{in}) de la norme, à partir de l'entropie d'entrée h_{in}.
- **Fonction non approuvée.** h_{out} est en plus plafonné par $0{,}999 \times n_{out}$ et par $h' \times n_{out}$, où h' est l'entropie par bit mesurée sur un million de sorties : $h_{out} = \min(\text{Output_Entropy}, 0{,}999\, n_{out}, h'\, n_{out})$.
- **Pleine entropie** (FIPS 140-3 IG D.K [4], SP 800-90C [3]). Une sortie est dite à pleine entropie si h_{out} est à $\varepsilon \le 2^{-32}$ près égal à n_{out} ; il faut pour cela une fonction approuvée et une marge d'au moins 64 bits : $\mathbf{h_{in} \ge n_{out} + 64}$.

5 Décider si une source est conforme

Une source est déclarée conforme si les cinq critères suivants sont remplis :

1. **Données** (§3.1.1). Au moins 1 000 000 d'échantillons bruts consécutifs, avec plus d'un symbole : une source bloquée est rejetée d'emblée.
2. **Entropie initiale H_I.** Par la voie IID si elle est justifiée et que l'hypothèse tient, sinon par les dix estimateurs non IID.
3. **Cohérence au redémarrage.** $X_{max} \le X_{cutoff}$ sur toutes les lignes et les colonnes.
4. **Entropie au redémarrage.** $\min(H_r, H_c) \ge H_I / 2$; l'entropie validée est $H = \min(H_r, H_c, H_I)$.
5. **Revendication.** H est au moins égale à la revendication H_{claim} du modèle ; on crédite alors la plus basse des deux valeurs.

6 Intégration dans un générateur hybride

Un générateur hybride associe une source d'entropie, évaluée selon SP 800-90B, à un DRBG qui étire sa graine : c'est la construction RBG2 de SP 800-90C [3]. Pour une force de sécurité s = 256 bits, le dimensionnement se fait en trois étapes.

6.1 Entropie à fournir au DRBG

Tableau 5. Entropie à fournir au DRBG pour une force de 256 bits.

Opération	Entropie requise E	Raison
Instanciation	384 bits (3s/2)	s bits d'entropie et s/2 bits de nonce
Réensemencement	256 bits (s)	Rétablit la force de sécurité après une compromission de l'état
Sortie à pleine entropie (RBG3)	320 bits (s + 64) par bloc de 256 bits	Marge de 64 bits de FIPS 140-3 IG D.K

6.2 Nombre d'échantillons bruts

À partir de l'entropie validée H, issue du test 3, le nombre d'échantillons à collecter est $N = \lceil E / H \rceil$.

Tableau 6. Nombre d'échantillons bruts par opération.

Source et entropie retenue	H (bit/éch.)	Instanciation 384	Réens. 256	Pleine entropie 320
jitterentropy [9], revendication de conception (osr = 3)	0,3333	1 152	768	960
Bruit thermique du lab 3, H validé (NT-03)	4,0927	94	63	79

6.3 Seuils des tests de santé

Les seuils des tests de santé se calculent à partir de l'entropie créditée H, pour un taux de fausse alarme $\alpha = 2^{-20}$:

- **RCT** (*Repetition Count Test*, §4.4.1) : le test échoue si une même valeur se répète $C = 1 + \lceil 20 / H \rceil$ fois de suite ;
- **APT** (*Adaptive Proportion Test*, §4.4.2) : dans une fenêtre de W = 512 échantillons (1 024 pour une source binaire), le test échoue si une valeur apparaît au moins C fois, C étant le plus petit entier dont la probabilité est $\le 2^{-20}$.

Tableau 7. Seuils des tests de santé ($\alpha = 2^{-20}$).

Source et entropie créditée H	RCT : C	APT : W	APT : C
jitterentropy, revendication (1/3 bit)	61	512	449
Bruit thermique du lab 3 (4,0927 bits)	6	512	59
Source binaire idéale (1 bit)	21	1 024	589

Aucun échantillon n'entre dans la graine sans avoir passé ces tests ; au premier échec, la graine en cours est jetée.

7 Enseignements des labs

La campagne de NT-03 applique les quatre tests à 22 jeux de données : sources saines, défauts de conception, effets d'environnement, pannes et sorties de DRBG. Les sources « physiques » y sont **simulées** à partir d'un modèle dont l'entropie est connue, ce qui permet de confronter la mesure à la théorie : 5,618 bits mesurés pour 5,65 attendus sur un bruit thermique. Six enseignements en ressortent.

1. **Les tests ne voient pas le déterminisme.** Une suite AES-256 à clé nulle passe les tests IID avec 7,87 bits par octet, et obtient encore 7,15 bits par la voie non IID, pour une entropie réelle nulle. Règle : ne jamais évaluer une sortie de DRBG ou de hachage.
2. **IID ne veut pas dire forte entropie.** Un convertisseur saturé passe les tests IID avec seulement 1,92 bit d'entropie sur 8.
3. **Un seul test suffit à rejeter l'hypothèse IID.** Un oscillateur lu lentement passe le khi-deux et la plus longue répétition, mais une seule statistique de permutation sur 19 le rejette.
4. **Les tests IID ont un taux de faux rejet.** Une source réellement IID est rejetée dans 2 à 3 % des cas, à cause du seuil des permutations ($C \leq 5$ sur 10 000 pour chacune des 19 statistiques) ; la norme impose alors la voie non IID.
5. **Seul le test de redémarrage voit certains défauts.** Une source dont les premiers échantillons sont identiques à chaque démarrage paraît normale en régime établi ; seul le test 3 la rejette.
6. **La marge de conditionnement est impérative.** SHA-256 recevant exactement 256 bits d'entropie ne produit que 251,69 bits en sortie ; avec 320 bits en entrée, la sortie est à pleine entropie.

8 Conclusion

libsp80090b permet d'industrialiser la qualification des sources d'entropie directement sur leur plateforme d'exécution. Elle réalise les quatre tests de SP 800-90B avec les mêmes résultats que l'outil du NIST, et fournit les paramètres du générateur hybride : le nombre d'échantillons N de la graine et les seuils des tests de santé RCT et APT.

La mesure reste un contrôle : l'entropie revendiquée vient d'abord du modèle de la source, et une sortie de DRBG trompe tous les tests. Pour un dossier de validation ESV, l'outil du NIST reste la référence.

9 Références

[1] M. Sönmez Turan, E. Barker, J. Kelsey, K. McKay, M. Baish, M. Boyle. *Recommendation for the Entropy Sources Used for Random Bit Generation*. NIST SP 800-90B, janvier 2018.

[2] National Institute of Standards and Technology. *SP800-90B_EntropyAssessment*. Code source, github.com/usnistgov/SP800-90B_EntropyAssessment.

[3] E. Barker, J. Kelsey, K. McKay, A. Roginsky, M. Sönmez Turan. *Recommendation for Random Bit Generator (RBG) Constructions*. NIST SP 800-90C, septembre 2025.

[4] National Institute of Standards and Technology. *Security Requirements for Cryptographic Modules*. FIPS PUB 140-3, 2019 ; Implementation Guidance, D.K.

[5] NIST CMVP. *Entropy Source Validation (ESV) Program*. Documentation du programme ESV.

[6] P. Hagerty, T. Draper. *Entropy Bounds and Statistical Tests*. NIST Random Bit Generation Workshop, 2012.

[7] J. Kelsey, K. A. McKay, M. Sönmez Turan. *Predictive Models for Min-Entropy Estimation*. CHES 2015, LNCS 9293.

[8] Y. Mori. *libdivsufsort — suffix-sorting library*. Code source, version 2.0.

[9] S. Müller. *Jitter RNG (jitterentropy)*. Documentation et code source, version 3.7.1, 2026.

[10] EPI Quantum Crypto team. *entropy-lab — collecter, tester et évaluer l'entropie d'un PC*. Entropy/entropy-lab/README.md, 2026.

[11] T. Hall, J. Kelsey, M. Sönmez Turan. *Entropy Sources — Importance and testing*. NIST, Information Security and Privacy Advisory Board, 26 octobre 2022.

[12] E. Barker, J. Kelsey. *Recommendation for Random Number Generation Using Deterministic Random Bit Generators*. NIST SP 800-90A Rev. 1, juin 2015.